

Meyy — questions for the advisor meeting (2026-09-04)

Companion to `Aruvi_External_Provider_Seam.html` (show him that sheet first) and the Technology Partnership & Production Roadmap PDF. Everything below is grounded in the repo as of today; nothing already decided is asked as open.

A. Where Meyy stands — the two-minute version to give him

Built and working locally. Mobile-first web app (Next.js) → FastAPI → `aruvi_core` engine. Five subjects, 11 subject-stages, ~1,000 certified plan files. The live service calls **no AI** — it serves pre-authored plans by deterministic selection; the AI authoring pipeline runs offline on the founder's machine and never ships. 22 named ports; every teacher record already keyed `tenant/user/year`. Account, academic year, cutover, chapter notes, export/erase (DPDP + Apple 5.1.1(v)), entitlement, invoicing, consent ledger, support, transactional email — all built behind ports with file adapters. 46 test files. Persona run done on the founder's phone.

Measured size. The entire migration unit (`data/cloud/`) is **84 MB** — 78 MB of that is the plan library; per-teacher state is kilobytes. Authoring data (7 MB) stays with the founder.

Stubs — the three things a partner replaces. (1) **Auth:** user id arrives in a header, OTP is 0000 client-side. (2) **Payments:** founder grants entitlement by CLI; cart, invoice series and consent exist, no gateway. (3) **Storage/DB:** local files behind the ports.

Missing entirely. Cloud deployment, managed DB + RLS, backups, monitoring/log rotation, secrets manager, SMS OTP provider, payment gateway/webhooks, **the mobile app** (the settled model makes the app the individual product — Individual = app only, Enterprise = website — and no app code exists yet), notification preferences, a dormancy job, the privacy notice's nine FIX items (real OTP, identifiers in query-string logs, sign-out residue, mobile stored in the erasure log, role/state/city missing from the export, Google Fonts leaking pre-login IPs, outbox/ PII outside the erase walk, notice not shown at trial sign-in, `_KEPT` list), serving the privacy notice, Ask Meyy redaction pass (the IP half readable by any trial account), the 20-teacher pricing test.

Clock. DPDP hard enforcement ~14 May 2027. Peak teacher planning is March-June.

B. Questions

1. Data architecture (84 MB total; security; AI-queryable operations)

1. **Two buckets, one boundary.** We keep shared read-only CONTENT (the library, norms, glossaries, legal texts) strictly apart from per-teacher STATE, and `data/cloud/` is the literal byte-for-byte migration unit. Given the size, is the right production shape *object store for content + managed Postgres for state*, or would you put everything — including the 78 MB library — in Postgres (JSONB) and skip the object store entirely?
2. **Twelve tables or one document table?** We have twelve `..Repository` ports, each a

- small JSON document keyed `tenant/user[/year]`. Should the partner write twelve adapters/tables with RLS, or one generic JSONB document table keyed (`kind, tenant, user, year`) behind a single adapter? What does each choice cost us when the institutional tier arrives (`tenant ≠ user`)?
3. **Is a beta on the file adapters acceptable?** A single VM with a persistent disk, nightly snapshots, and the existing file adapters would run ~100 teachers today with zero new code. The ports let us swap to Postgres later. Would you do that for beta, or is the durability/concurrency risk not worth it even at this size?
 4. **PII as the primary key.** Today the user id IS the mobile number and it is the folder key everywhere (state, erasure log, consent ledger). Our own principle is "do the re-filing before launch, when it is free". Should we move to a surrogate UUID now, with mobile/email as attributes — and is that the single most valuable pre-migration change?
 5. **Region and residency.** DPDP has no localisation duty for us (blacklist model), so India hosting is a trust choice, not a legal must. Do you still recommend an India region? Which managed-Postgres providers do you trust there (Supabase Mumbai, AWS ap-south-1, GCP Mumbai), and does the choice matter at this size?
 6. **Backups vs the privacy notice.** Our notice will promise "purged from backups within 30 days". What PITR/snapshot retention do you set so that promise is true, and how do we prove it?
 7. **Querying operations with AI, safely.** We want to ask an AI "how many teachers reached week 2? which chapters get re-served most?" without ever pointing an LLM at the production DB. What pattern do you recommend — read-only replica with PII-stripped views, an MCP server over those views, text-to-SQL with limits? And what operational telemetry should we *start* logging (we log nothing today) that DPDP purpose-limitation still permits?
 8. **Protecting the library itself.** The plan library and the Ask Meyy bank are the IP; a trial account can already reach both through the app. Beyond serving only via the API: rate limits on /plans and export, signed short-lived URLs, watermarked exports — what is worth doing at launch and what is theatre?
 9. **Edition-year versioning.** The library is re-versioned every academic year (the year is a label; the cache key is engine + constitution). Any objection to keeping that layout in an object store with a yearly carry-over copy, versus a versioned-object feature?
 10. **Future shapes.** Voice chapter notes (a speech-to-text processor), live LLM generation, and a school admin dashboard are all specced but unbuilt. Does anything in your recommended schema make any of the three expensive later?

2. Authentication (mobile-first; mobile + email ids; device control)

11. **Managed IdP or own OTP?** Supabase Auth / Firebase Auth phone / Auth0 / Cognito versus a thin OTP service of our own behind the AuthProvider port. For a one-person company, which failure modes matter most (SMS delivery, cost per OTP, vendor lock-in)?
12. **SMS OTP in India.** DLT registration, sender id, provider choice (MSG91, Exotel, Twilio, Firebase), per-OTP cost at 1,000 → 100,000 teachers, and fallbacks when SMS is late (WhatsApp OTP, email OTP, missed call). What do teachers on budget Androids actually receive reliably?
13. **Mobile as the canonical id.** Sign-in is registered-only and accepts mobile or email;

- email resolves to the canonical mobile. How should we handle SIM/mobile change, lost phone, and recovery — and does that argue again for a surrogate id (Q4)?
14. **Session model on a phone.** Long-lived refresh token + device biometrics for re-entry (device-local, no server change) — is that the right default? Token lifetimes you'd set for an app used at 8:20 AM in a staff room.
 15. **Device count control — worth it?** Our fence is "the phone is personal": one account, one handset. Is limiting active devices (e.g. 1 mobile + web for enterprise) worth the friction, or is rate-limiting serves/exports a better fence against the "LP printing press" abuse? If we do limit: device registration at OTP, per-device refresh tokens, "sign out other devices"?
 16. **Abuse at the free door.** Trial = 3 chapters per verified number. Should we block VoIP/ virtual numbers, and how do the IdPs above handle OTP brute force, replay and SIM swap?
 17. **One identity across channels.** Individual on the app, school on the web — same IdP, same account, entitlement tagged by channel. Any reason to run two identity systems?
 18. **What must be fixed before the notice goes live** (from our own audit): identifiers out of query strings and access logs, 12-month log rotation, full local-storage clearing on sign-out. Anything you'd add to that list for a mobile-first sign-in?

3. Subscriptions during beta — apps, not website

19. **Which app path for beta?** No app code exists; the web app is the working product. Options: (a) a real Expo/React-Native app, (b) an Expo shell around the web app, (c) PWA / Trusted Web Activity on Play. Apple rejects thin wrappers (4.2); what would you ship for beta, and does any of the existing web code carry over?
20. **Distributing a beta without the stores' payment rails.** TestFlight external testing and Play closed/internal tracks — what are the current limits (tester counts, 14-day testing requirement for new Play accounts, build expiry), and can a beta legitimately collect money at all?
21. **Run beta on manual grants?** Our ManualBillingProvider + CLI already IS a billing system: verify teachers, grant scopes by hand, invoice with GST. Is "free beta, founder grants entitlement, charge at GA" the cleanest path — and if we do take money in beta off-app (UPI/Razorpay link), where exactly is the Apple/Google policy line when the app itself never mentions a purchase?
22. **IAP obligations and India-specific rules.** Apple IAP (15% under the Small Business Program) and Google Play Billing (15% for subscriptions) — plus Google's User Choice Billing in India after the CCI order. What is the current, actually-enforced position?
23. **Store product type for "N independent annual scopes".** Our unit is teacher × subject-stage, ₹500/yr each, a two-subject teacher buys two, rolling annual. Apple subscription groups are mutually exclusive — so 11 groups? Non-renewing subscriptions? Consumables? What maps cleanly, and what does renewal look like per store?
24. **Merchant of record and our invoice series.** If Apple/Google are MoR in India, does Meyy still issue its own GST invoice (our MEY/2026-27/NNNN series exists), or does that change? Store payout timing and its effect on a solo company's cash?
25. **Webhooks into the seam.** App Store Server Notifications v2 and Play RTDN → one BillingProvider adapter setting source = ios|android; refunds, grace periods, lapsed →

"keeps her plans, loses the tracker". Any pitfall in that mapping?

26.**The price test.** ₹500/subject-stage is a working figure; the 20-teacher test (week-2 return + the time-fitting reaction, then willingness-to-pay) has not run. Can the beta cohort *be* that test, and how would you size and run it?

4. Security protocols — what to insist the partner does

27.**Baseline.** RLS with the service key never in a client; secrets in a manager, not env files; HTTPS/HSTS/CORS; rate limits on OTP, serve, export; dependency scanning; CI check that data/authoring/ can never deploy. What is missing from that list for our shape?

28.**Logs and DPDP.** The Rules require a year of server logs; the notice promises they carry no account identifier. Beyond moving ids out of URLs — what logging discipline (structured logs, PII scrubbing, retention) should the partner commit to in writing?

29.**Mobile app hardening.** Tokens in Keychain/Keystore, no secrets in the bundle, certificate pinning — which of these matter for an app with no AI key and no payment data of its own?

30.**Email domain.** SPF/DKIM/DMARC on meyy.in, and a real mailbox behind support@meyy.in — every case copy goes there. Gmail as the sender is a disclosed processor today; when does it stop being acceptable?

31.**Operating production as one person.** Today the founder would SSH and edit JSON. What is the minimum admin surface with an audit log (grant/revoke entitlement, trial reset, erase confirm) so that never happens?

32.**Breach and incident.** DPDP breach notification to the Board and to affected teachers — what runbook, and who is on call in a one-person company with a retainer partner?

33.**Pre-launch checks.** Is a paid penetration test worth it at this size, or is a partner-run OWASP pass plus automated scanning enough for launch?

34.**Children's data by accident.** Chapter notes are free text; a teacher may name a student. We chose "reserved right, no detector". Would you leave it manual?

5. Only if there is time — the partnership itself

35.Fixed assessment first, then milestones, then a monthly retainer — is that structure right for a sub-GB product, and what would you cap the assessment at?

36.Handover test: "another competent developer takes over without the original explaining it". What artefacts would you demand at each milestone to make that true?

37.What would you tell a partner NOT to rebuild? (Our answer: nothing above the ports.)

C. Not for this meeting, but on the launch path (non-tech)

NCERT written permission before commercial launch · trademark filing for MEYY (classes 9/41/42) · accountant: GST retention (8 y, Companies Act §128) and MoR question (Q24) · counsel: privacy notice v0.1 review, agreement v0.5 · registered office for the notice.